Travaux pratiques – Attaquer une base de données mySQL

Objectifs

Au cours de ces travaux pratiques, vous aurez accès à un fichier PCAP provenant d'une précédente attaque contre une base de données SQL.

Partie 1: Ouvrir Wireshark et charger le fichier PCAP.

Partie 2: Examiner l'attaque par Injection SQL.

Partie 3: L'attaque par injection SQL continue...

Partie 4: L'attaque par injection SQL fournit des informations système.

Partie 5: L'attaque par injection SQL et les informations des tables.

Partie 6: L'attaque par injection SQL se termine.

Contexte/scénario

Les attaques par injection SQL permettent aux hackers de taper des instructions SQL dans un site web et de recevoir une réponse de la base de données. Ils peuvent ainsi altérer les données se trouvant dans la base de données, usurper des identités et commettre divers méfaits.

Un fichier PPCE a été créé pour que vous puissiez voir une précédente attaque contre une base de données SQL. Vous allez également voir des attaques de base de données SQL et répondre aux questions.

Ressources requises

- Poste de travail CyberOps VM

Instructions

Utilisez Wireshark, un analyseur de paquets réseau courant, pour analyser le trafic réseau. Après avoir lancé Wireshark, ouvrez une capture réseau précédemment enregistrée pour étudier les différentes étapes d'une attaque par injection SQL contre une base de données SQL.

Partie 1 : Ouvrir Wireshark et charger le fichier PCAP.

Vous pouvez ouvrir l'application Wireshark de différentes manières sur un poste de travail Linux.

a. Démarrez le poste de travail virtuel CyberOps.

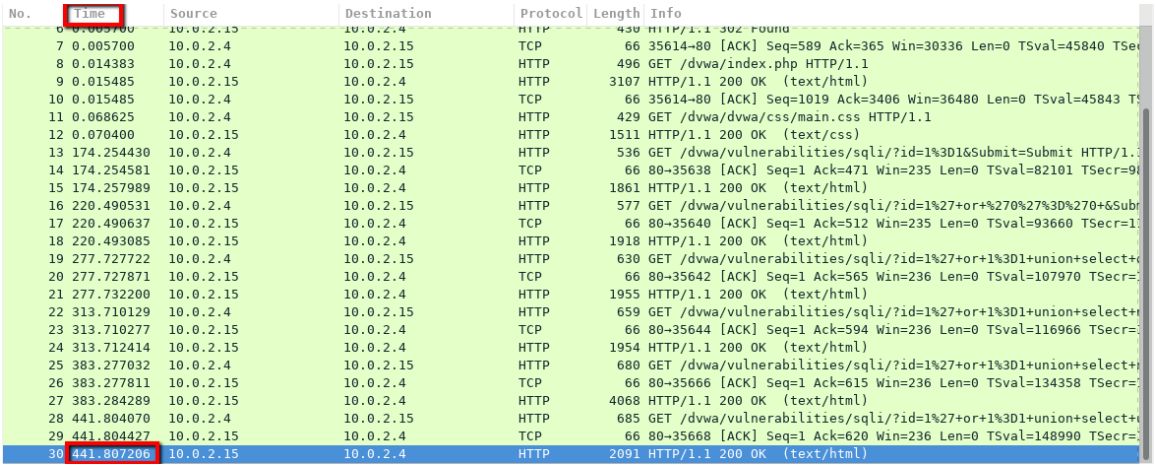
b. Cliquez sur **Applications > CyberOPS > Wireshark** sur le bureau et accédez à l'application Wireshark.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Dans l'application Wireshark, cliquez sur **Open** au milieu de l'application sous Files.

d. Dans le répertoire **/home/analyst/** recherchez **lab.support.files**. Dans le répertoire **lab.support.files** recherchez et ouvrez le fichier **SQL_Lab.pcap**.

e. Le fichier PCAP s'ouvre dans Wireshark et affiche le trafic réseau capturé. Ce fichier de capture couvre une période de 8 minutes (441 secondes), soit la durée de cette attaque par injection SQL.



No.	Time	Source	Destination	Protocol	Length	Info
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614→80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSe
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614→80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 T
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429	GET /dvwa/dvwa/css/main.css HTTP/1.1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80→35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82101 TSecr=9
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+%270%27%3D%270+&Subr
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80→35640 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93660 TSecr=1
18	220.493085	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/html)
19	277.727722	10.0.2.4	10.0.2.15	HTTP	630	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+
20	277.727871	10.0.2.15	10.0.2.4	TCP	66	80→35642 [ACK] Seq=1 Ack=565 Win=236 Len=0 TSval=107970 TSecr=
21	277.732200	10.0.2.15	10.0.2.4	HTTP	1955	HTTP/1.1 200 OK (text/html)
22	313.710129	10.0.2.4	10.0.2.15	HTTP	659	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+
23	313.710277	10.0.2.15	10.0.2.4	TCP	66	80→35644 [ACK] Seq=1 Ack=594 Win=236 Len=0 TSval=116966 TSecr=
24	313.712414	10.0.2.15	10.0.2.4	HTTP	1954	HTTP/1.1 200 OK (text/html)
25	383.277032	10.0.2.4	10.0.2.15	HTTP	680	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+
26	383.277811	10.0.2.15	10.0.2.4	TCP	66	80→35666 [ACK] Seq=1 Ack=615 Win=236 Len=0 TSval=134358 TSecr=
27	383.284289	10.0.2.15	10.0.2.4	HTTP	4068	HTTP/1.1 200 OK (text/html)
28	441.804070	10.0.2.4	10.0.2.15	HTTP	685	GET /dvwa/vulnerabilities/sqli/?id=1%27+or+1%3D1+union+select+
29	441.804427	10.0.2.15	10.0.2.4	TCP	66	80→35668 [ACK] Seq=1 Ack=620 Win=236 Len=0 TSval=148990 TSecr=
30	441.807206	10.0.2.15	10.0.2.4	HTTP	2091	HTTP/1.1 200 OK (text/html)

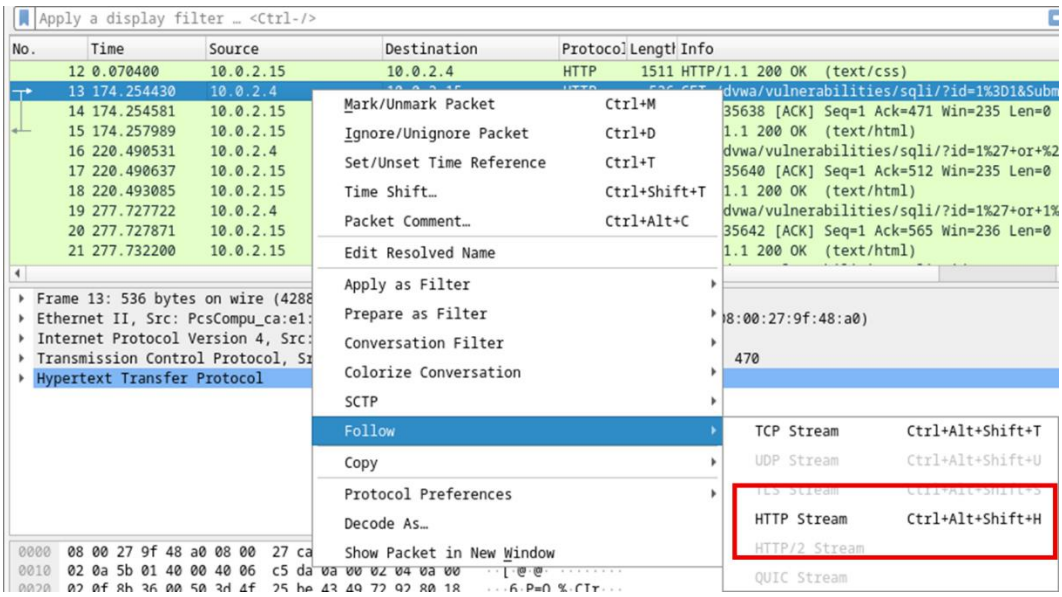
Quelles sont les deux adresses IP impliquées dans cette attaque par injection SQL selon les informations affichées ?

Partie 2 : Examiner l'attaque par Injection SQL.

Au cours de cette étape, vous allez visualiser le début d'une attaque.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

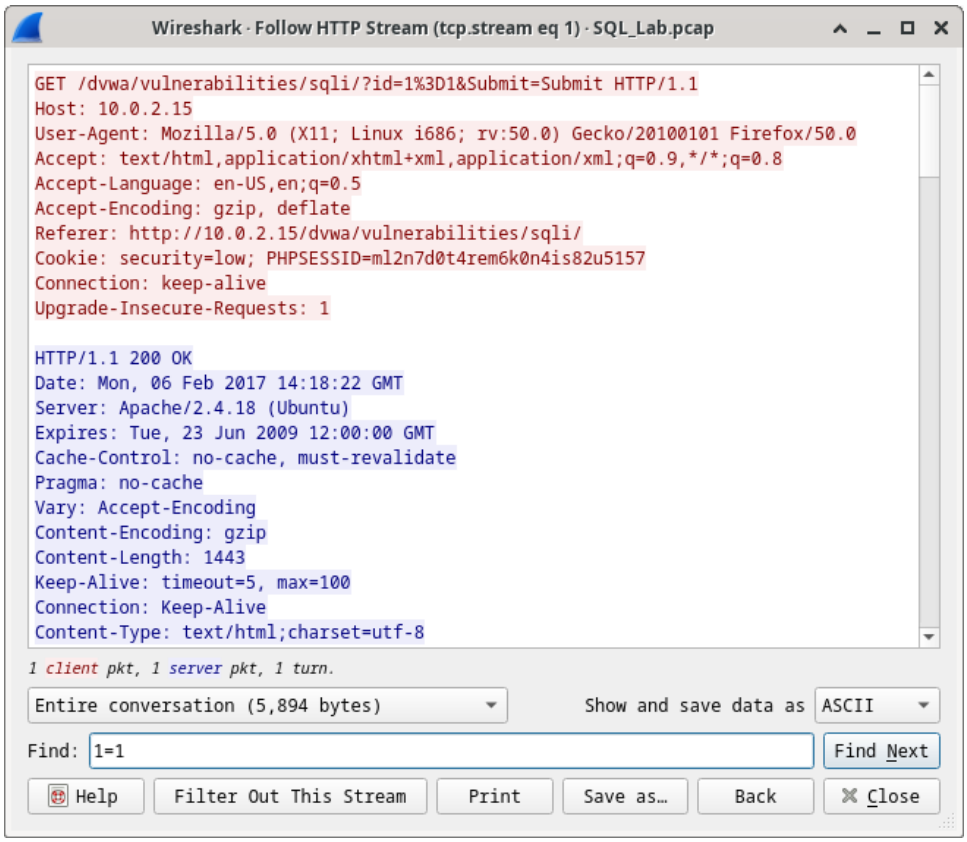
a. Dans la capture Wireshark, cliquez avec le bouton droit de la souris sur la ligne 13 et sélectionnez **Follow** > **HTTP Stream**. La ligne 13 a été choisie, car il s'agit d'une requête GET HTTP. Cette fonction permet de suivre le flux de données tel que la couche application le voit et mène au test des requêtes à la recherche d'injection de code SQL.



Le trafic de la source s'affiche en rouge. La source a envoyé une requête GET à l'hôte 10.0.2.15. En bleu, l'appareil de destination répond à la source.

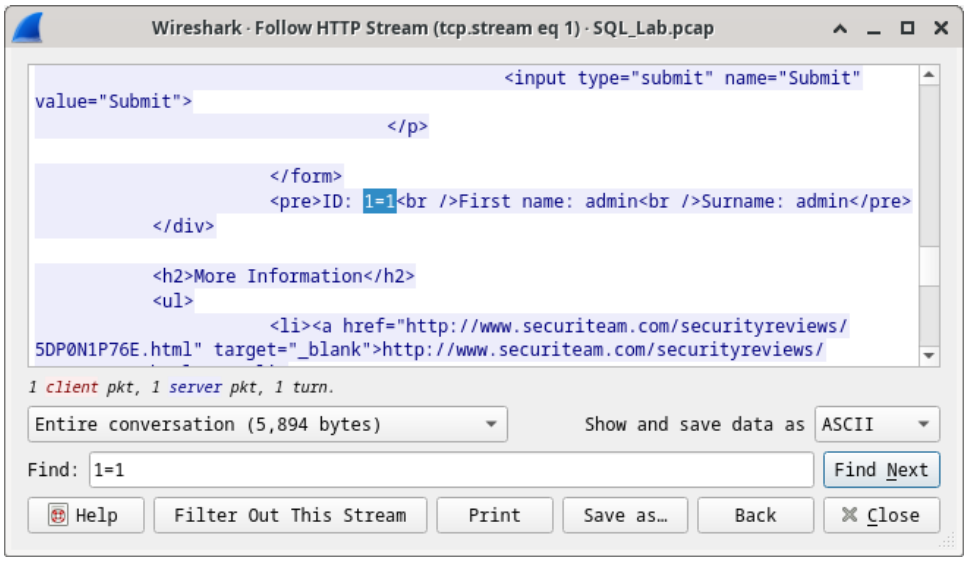
© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

b. Dans le champ **Find**, saisissiez **1=1**. Cliquez sur **Find Next**.



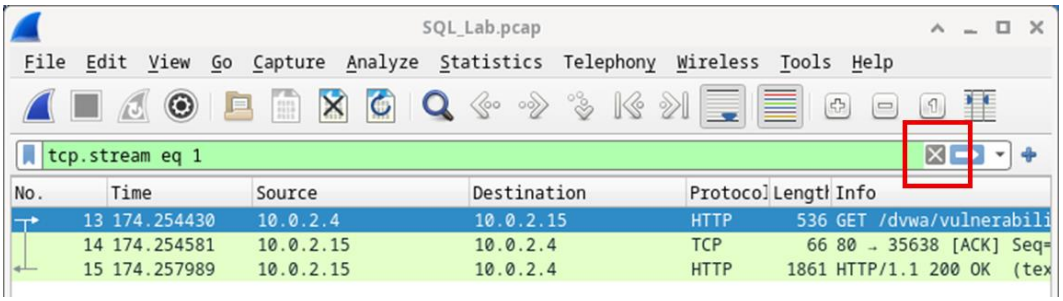
© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Le hacker a saisi une requête (1=1) dans une boîte de recherche d'ID d'utilisateur sur la cible 10.0.2.15 pour savoir si l'application est vulnérable à l'injection de code SQL. Au lieu de répondre avec un message d'échec de connexion, l'application répond avec un enregistrement d'une base de données. Le hacker a donc vérifié que la base de données répond lorsqu'il tape une commande SQL. La chaîne de recherche 1=1 crée une instruction SQL qui sera toujours vraie. Dans l'exemple, quelle que soit la requête saisie dans le champ, elle sera toujours vraie.



d. Fermez la fenêtre Follow HTTP Stream.

e. Cliquez sur **Clear display filter** pour afficher la conversation Wireshark entière.



Partie 3 : L'attaque par injection SQL continue...

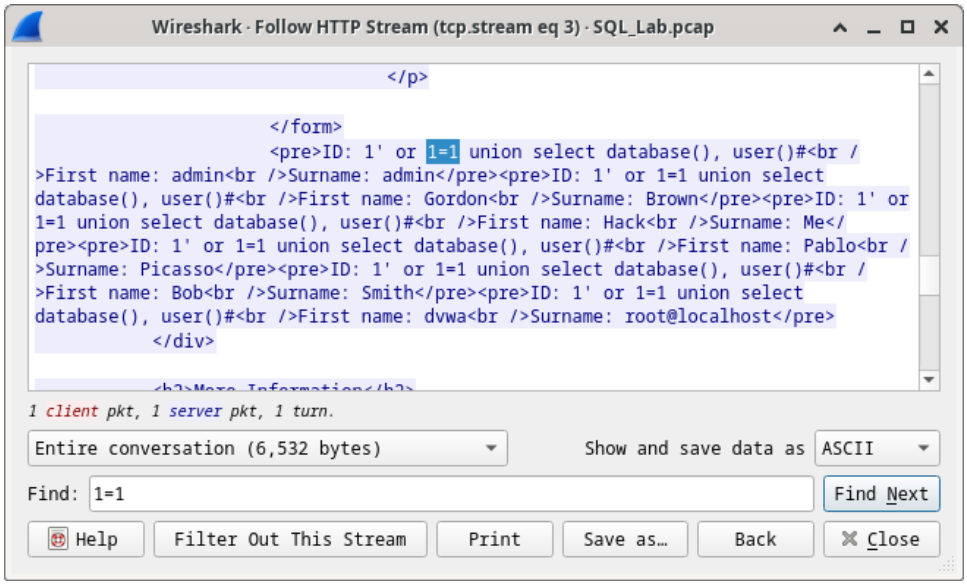
Au cours de cette étape, vous allez voir la suite d'une attaque.

a. Dans la capture Wireshark, cliquez avec le bouton droit de la souris sur la ligne 19 et sélectionnez **Follow** > **HTTP Stream**.

b. Dans le champ **Find**, saisissiez **1=1**. Cliquez sur **Find Next**.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Le hacker a saisi une requête (1' or 1=1 union select database(), user()#) dans une boîte de recherche d'ID d'utilisateur sur la cible 10.0.2.15. Au lieu de répondre avec un message d'échec de connexion, l'application répond avec les informations suivantes :



Le nom de la base de données est **dvwa** et l'utilisateur de la base de données est **root@localhost**. Plusieurs comptes d'utilisateurs sont également affichés.

d. Fermez la fenêtre Follow HTTP Stream.

e. Cliquez sur **Clear display filter** pour afficher la conversation Wireshark entière.

Partie 4 : L'attaque par injection SQL fournit des informations système.

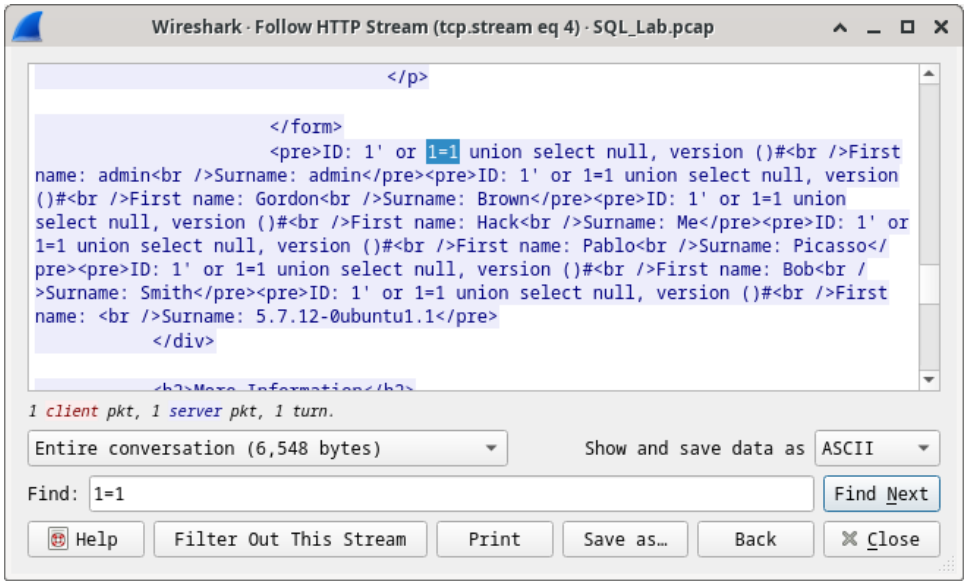
Le hacker continue et commence à cibler des informations plus précises.

a. Dans la capture Wireshark, cliquez avec le bouton droit de la souris sur la ligne 22 et sélectionnez **Follow** > **HTTP Stream**. Le trafic source indiqué en rouge envoie la requête GET à l'hôte 10.0.2.15. En bleu, l'appareil de destination répond à la source.

b. Dans le champ **Find**, saisissiez **1=1**. Cliquez sur **Find Next**.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Le hacker a saisi une requête (1' or 1=1 union select null, version ()#) dans une boîte de recherche d'ID d'utilisateur sur la cible 10.0.2.15 pour trouver l'identifiant de la version. Notez l'identificateur de version à la fin de la sortie juste avant le </pre>. code HTML de fermeture.



Quelle est la version ?

d. Fermez la fenêtre Follow HTTP Stream.

e. Cliquez sur **Clear display filter** pour afficher la conversation Wireshark entière.

Partie 5 : L'attaque par injection SQL et les informations des tables.

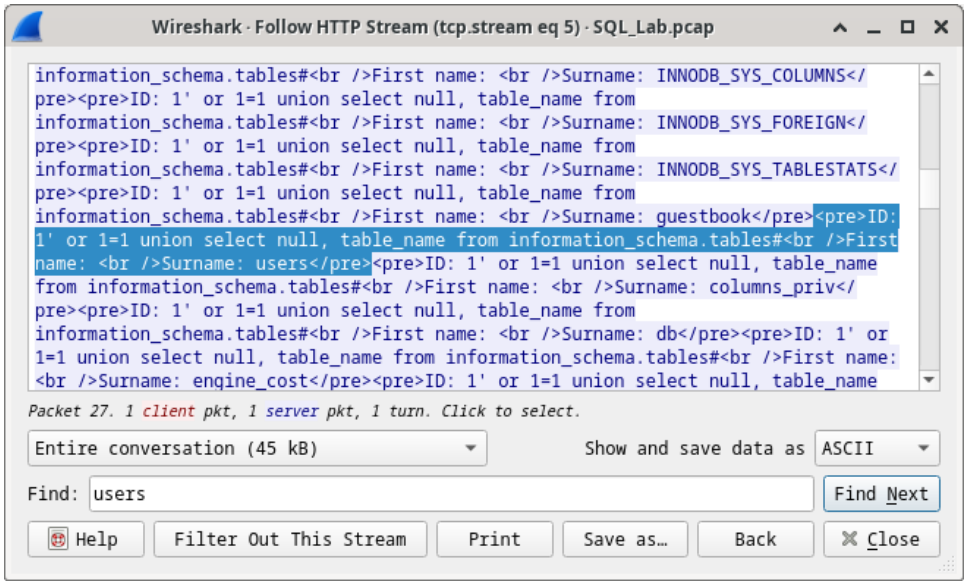
Le hacker sait qu'il y a de nombreuses tables SQL contenant beaucoup d'informations. Le hacker essaie de les trouver.

a. Dans la capture Wireshark, cliquez avec le bouton droit de la souris sur la ligne 25 et sélectionnez **Follow** > **HTTP Stream**. La source est indiquée en rouge. L'appareil source a envoyé une requête GET à l'hôte 10.0.2.15. En bleu, l'appareil de destination répond à la source.

b. Dans le champ **Find**, saisissez **les utilisateurs**. Cliquez sur **Find Next**.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Le hacker a saisi une requête (1'or 1=1 union select null, table_name from information_schema.tables#) dans une boîte de recherche d'ID d'utilisateur sur la cible 10.0.2.15 pour voir toutes les tables de la base de données. Une sortie indiquant de nombreuses tables est générée, car le hacker a spécifié « null » sans plus de précision.



Qu'obtient le hacker avec la commande modifiée (**1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'**) ?

d. Fermez la fenêtre Follow HTTP Stream.

e. Cliquez sur **Clear display filter** pour afficher la conversation Wireshark entière.

Partie 6 : L'attaque par injection SQL se termine.

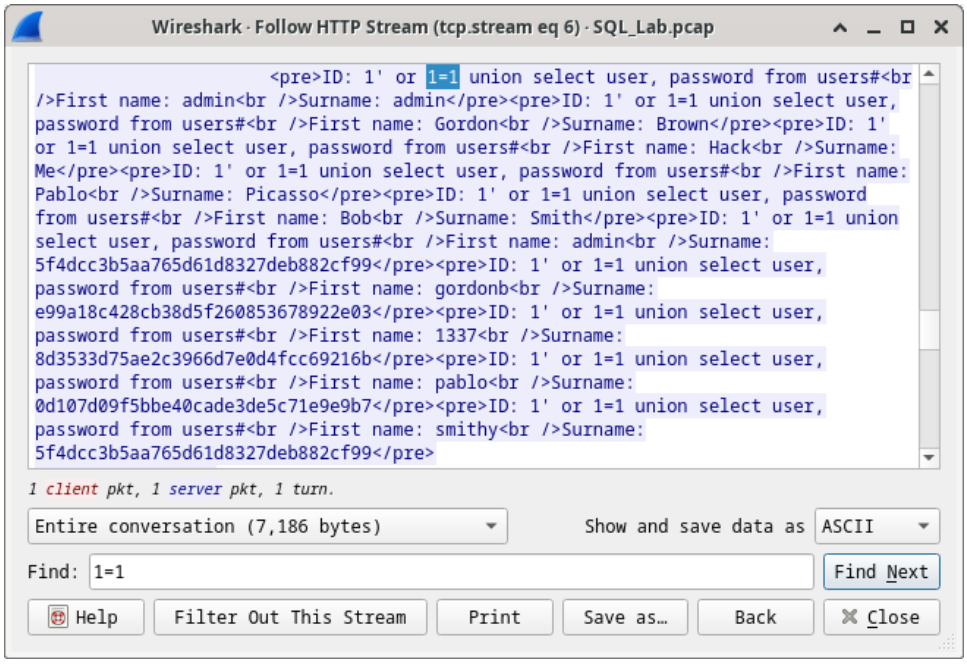
L'attaque se termine ayant permis au hacker de récupérer le meilleur butin possible : les valeurs de hash des mots de passe.

a. Dans la capture Wireshark, cliquez avec le bouton droit de la souris sur la ligne 28 et sélectionnez **Follow** > **HTTP Stream**. La source est indiquée en rouge. L'appareil source a envoyé une requête GET à l'hôte 10.0.2.15. En bleu, l'appareil de destination répond à la source.

b. Cliquez sur **Find** et tapez **1=1**. Recherchez cette entrée. Lorsque le texte est trouvé, cliquez sur **Cancel** dans la zone de recherche de texte.

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Le hacker a saisi une requête (1'or 1=1 union select user, password from users#) dans une boîte de recherche d'ID d'utilisateur sur la cible 10.0.2.15 pour extraire les noms d'utilisateurs et les valeurs de hash des mots de passe !



À quel utilisateur correspond la valeur de hash de mot de passe 8d3533d75ae2c3966d7e0d4fcc69216b ?

c. Utilisez un site web tel que https://crackstation.net/ et copiez cette valeur dans le déchiffreur de valeur de hash de mots de passe pour le pirater.

Quel est le mot de passe en texte clair ?

d. Fermez la fenêtre Follow HTTP Stream. Fermez les fenêtres ouvertes.

Questions de réflexion

1. Quel est le risque encouru lorsque des plates-formes utilisent le langage SQL ?
2. Naviguez sur Internet et recherchez comment «empêcher les attaques par injection SQL». Quelles sont les 2 méthodes ou mesures à appliquer pour empêcher les attaques par injection SQL ?

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco